Lab 09 — Phishing Email Analysis (SPF / DKIM / DMARC)

> **SY0-701 Objective 2.2** — Explain common threat vectors and attack surfaces
>
> **Domain 2** — Threats, Vulnerabilities, and Mitigations (22%) · **Time:** ~25 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: dissect a spoofed email header and prove, using the sender domain's DNS records, that the message was forged.

You'll build: a header-analysis workflow that exposes an SPF/DKIM/DMARC spoofing attempt.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; internet access for DNS lookups; tools installed in step 1.

Background

- **Phishing** is the top human threat vector: a fraudulent message luring the victim to a fake site or malicious attachment.
- **SPF** (Sender Policy Framework) is a DNS TXT record listing the IPs allowed to send mail for a domain.
- **DKIM** (DomainKeys Identified Mail) adds a cryptographic signature; the public key lives in a DNS TXT record at a selector.
- **DMARC** tells receivers what to do when SPF or DKIM fail (none, quarantine or reject) and where to send reports.
- Reading the header plus these three records is how you confirm a message really came from the claimed sender.

Steps

1. Install the DNS and mail tools

```
apt-get update -qq && apt-get install -y dnsutils swaks
```

2. Save a suspicious email header

This synthetic header *claims* to be from PayPal but was relayed through an unrelated host.

```
cat > mail.eml <<'EOF'
Return-Path: <bounce@mailer-cheap-host.ru>
Received: from unknown (203.0.113.77) by mx.example.com
From: PayPal Service <service@paypal.com>
Subject: Your account has been limited
```

```
EOF
cat mail.eml
```

3. Read the Received and Return-Path lines

The envelope sender and relay IP rarely match a legitimate sender — the first red flag.

```
grep -Ei 'received|return-path|^from' mail.eml
```

4. Query the claimed sender's SPF record

Pull the real SPF policy for the domain in the `From` header.

```
dig +short TXT paypal.com | grep -i spf
```

5. Pull the DMARC policy

The `_dmarc` record shows how receivers should treat failures (look for `p=reject` or `p=quarantine`).

```
dig +short TXT _dmarc.paypal.com
```

6. Pull a DKIM selector key

DKIM keys live under `selector._domainkey.domain`. Selectors vary by sender; try a common one.

```
dig +short TXT selector1._domainkey.paypal.com
dig +short TXT s1._domainkey.paypal.com
```

7. Compare the sending IP to the SPF list

This is a reasoning step. The relay IP in the header (`203.0.113.77`) is **not** in PayPal's published SPF record, so SPF would fail. There is no valid DKIM signature from the claimed domain, so DKIM is `none`. With `p=reject` in DMARC, a correctly configured receiver would reject the message.

8. Summarise the verdict

```
echo "spf=fail  dkim=none  dmarc=fail  =>  message is SPOOFED (phishing)"
```

Test it

Confirm the analysis conclusion is reproducible.

```
dig +short TXT paypal.com | grep -qi 'v=spf1' && echo "Real SPF record retrieved"
dig +short TXT _dmarc.paypal.com | grep -qi 'p=' && echo "DMARC policy retrieved"
grep -qi '203.0.113.77' mail.eml && echo "Relay IP in header is NOT in the SPF list => SPF
fail => spoofed"
```

Expected: the real SPF and DMARC records are retrieved, and the header's relay IP is shown to be outside the authorised SPF list, proving the spoof.

Troubleshooting

Symptom	Fix
`dig` returns nothing	DNS may be filtered; try `dig @1.1.1.1 +short TXT paypal.com`.
DKIM selector empty	Selectors differ per sender; a legitimate signed mail names its selector in the `DKIM-Signature` header.
`swaks` prompts for input	Add `--quit-after RCPT` and `--suppress-data` to keep it non-interactive.

Challenge

Build your own anti-spoofing policy: write the SPF, DKIM selector and DMARC TXT records you would publish for a domain called `example-bank.test`, choosing an appropriate DMARC policy and explaining why.

Reflection

Objective 2.2 lists message-based vectors and brand impersonation. How do SPF, DKIM and DMARC together defend against brand impersonation, and which one actually *stops* delivery?

Exam tips

- SPF checks the sending IP; DKIM checks a cryptographic signature; DMARC decides what to do on failure and adds reporting.
- Phishing = email, vishing = voice, smishing = SMS; whaling targets executives.
- Business email compromise uses a spoofed or hijacked executive account to request fraudulent transfers.
- A mismatch between the `From` domain and the `Return-Path`/relay is a classic spoofing indicator.

References

- M3AAWG Email Authentication — https://www.m3aawg.org
- RFC 7208 (SPF), RFC 6376 (DKIM), RFC 7489 (DMARC) — https://www.rfc-editor.org
- MITRE ATT&CK Phishing (T1566) — https://attack.mitre.org/techniques/T1566/
- APWG Phishing Trends — https://apwg.org
